

COMMONWEALTH OF AUSTRALIA

Copyright Regulations 1969

WARNING

This material has been copied and communicated to you by or on behalf of The University of Newcastle pursuant to Part VB of the Copyright Act 1968 (the Act).

The material in this communication may be subject to copyright under the Act. Any further copying or communication of this material by you may be the subject of copyright protection under the Act.

Do not remove this notice.

SENG1050

Web Technologies

Week 11 - Encryption

Lecture Outline

- ❑ Foundations of Cryptography
- ❑ Symmetric vs. Asymmetric Encryption
- ❑ Data Integrity
- ❑ Strong Cryptography
- ❑ Public Key Certificates
- ❑ Secure Connection
- ❑ Pretty Good Privacy (PGP)

Recall from last week: Encoding and Compression

- ❑ We have been using 'efficient and optimised' as shorthand for a website that is **scalable (week 7)**, **dynamic (week 8)**, **attractive to both humans and computers**, **responsive (week 9)**, **fast, reliable (weeks 9 & 10)**, and **secure (weeks 11 and 12)**.
- ❑ Last week, we finished looking at how we can improve the speed and performance of our website, by implementing compression to reduce the size of our files, and thereby reduce the time needed for a client to load our website.
- ❑ The last issue we need to address is security – people will not want to visit a website that they cannot trust to keep their data secure. We will explore this problem from two angles, securing data on the endpoints (on the clients and servers), and securing the data during transmission. This week, we will start by looking at how to secure data during transmission through the use of encryption.

Foundations of Cryptography

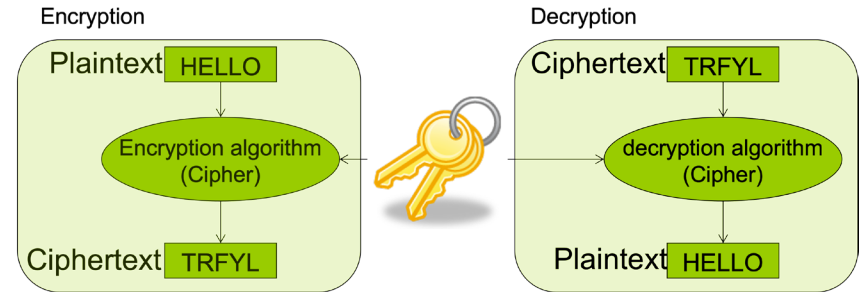


Encryption

- ❑ **Encryption**: The process of transforming plain text or data into **cipher text** that cannot be read by anyone other than the sender and receiver
- ❑ Purpose: **Secure stored information and information transmission**
- ❑ To encrypt or decrypt, you need
an algorithm + a key

Cryptography Definitions

- ❑ Plaintext - a message
- ❑ Ciphertext - an encrypted message
- ❑ Encryption - plaintext $\rightarrow$ ciphertext
- ❑ Decryption - ciphertext $\rightarrow$ plaintext
- ❑ Cipher - encryption algorithm



Encryption and the Internet

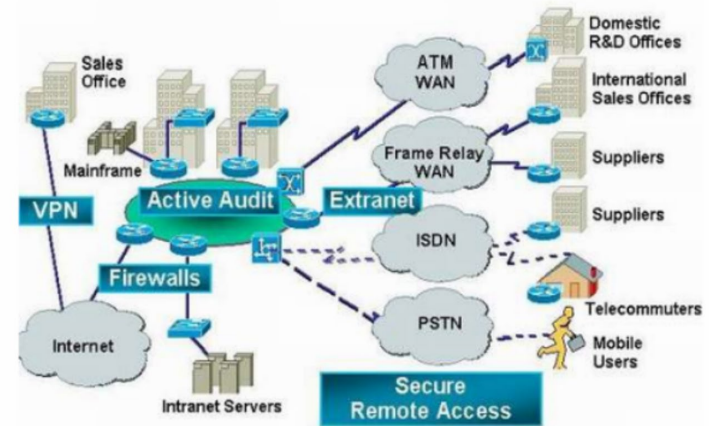
- ❑ Not an early priority for Internet developers
 - Most protocols work on plaintext messages
 - Developed mostly through free work at the University level
 - Open design, sharing and public information were the driving forces for the Internet

Encryption and the Internet

- ❑ Priorities have changed in the last 10 years
 - More company, government and private (i.e., secret) information being transmitted
- ❑ Not a new problem – Military networks have long been used for secret information
 - Usually isolated on a separate network, shielded from the Internet

Who Needs Cryptography?

- ❑ Electronic Funds Transfer – between banks
- ❑ Electronic Funds Transfer – EFTPOS, ATMs
- ❑ Credit card number across the web
- ❑ Bank records and other financial data
- ❑ Business/Government communications
- ❑ Product development data
- ❑ Your personal files
- ❑ Student grades

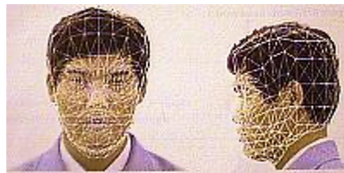
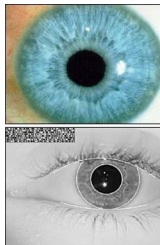




Fundamental Reasons for Cryptography

1. Authentication

- ❑ The receiver of the message can ascertain and validate its origin. Such schemes are based on:
 - Something you “know” (password)
 - Something you “have” (swipe card, *SecureId* or other device)
 - Something you “are” (voiceprint, fingerprint, retinal scan – biometrics, face detection)





Fundamental Reasons for Cryptography

2. Integrity

- ☐ The receiver can verify that the message was not modified during the transmission

3. Non-repudiation

- ☐ The sender cannot deny that they sent the message

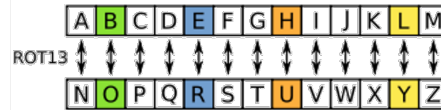
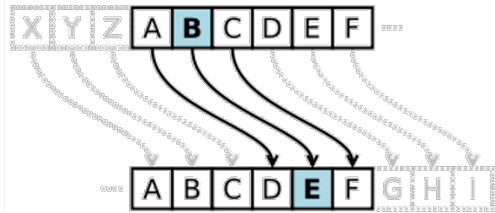
4. Confidentiality

- ☐ A message can be sent without “eavesdroppers” being able to read it

A VERY Simple Example (Caesar Cipher)

- Plaintext: This is a secret sentence
- Ciphertext: Uijt jt b tfdsfu tfoufodf
- Cipher is a very basic transposition of letters
 - $a \rightarrow b, b \rightarrow c, c \rightarrow d, \dots$
- The “key” is the number of letters to transpose
 - Caesar cipher used a **shift of 3**
- What is the basic problem with this method?
 - A very small set of permutations available – only 26
 - Only have to “try” 26 keys to find the correct one

A VERY Simple Example (Caesar Cipher)



A photograph of a classical bust of Julius Caesar, wearing a laurel wreath.

shift 3

plainText the quick brown fox jumps over the lazy dog

cipherText WKH TXLFN EURZQ IRA MXPSV RYHU WKH ODCB GRJ

A VERY Simple Example (Caesar Cipher)

- ❑ Plaintext: This is a secret sentence
- ❑ Ciphertext: Uijt jt b tfdsfu tfoufodf
- ❑ This is a very basic transposition of letters
 - $a \rightarrow b, b \rightarrow c, c \rightarrow d, \dots$
- ❑ The “key” is the number of letters to transpose
 - Caesar cipher used a shift of 3
- ❑ What is the basic problem with this method?
 - A very small set of permutations available
 - only 26
 - Only have to “try” 26 keys to find the correct one

Mono-Alphabetic Substitution

- ❑ Where a letter of plaintext **always** produces the same letter of ciphertext.

- ❑ Plaintext: **a b c d e f g h i j k l m**

- ❑ Ciphertext: **Q R S K O W E I P L T U Y**

- ❑ There are $26!$ different cipher alphabets! Far too many to try them all.

- ❑ But it is still not secure. Why?

- The letter frequencies and underlying patterns are unchanged (recall statistical frequency)
 - **e** is the most common letter, lets try to replace O with **e**
 - **the** is a very common word, ...

Ftt bdv bfhvq efno ukvj f tnmvbnxv ic bdv fkvjfyv Fxvjnlfz
fjv qevzb ic bdv yukvjzxvzb nz tvqq bdfz f qvluzo.

Pnx Mnviny V, F, N, B, Z – E, T, A, I, N, bdv – the

the t e e et e the
Ftt bdv bfhvq efno ukvj f tnmvbnxv ic bdv

e e e e et the e et
fkvjfyv Fxvjnlfz fjv qevzb ic bdv yukvjzxvzb

e th e
nz tvqq bdfz f qvluzo.

e
Pnx Mnviny

All the tae a e al et e the
Ftt bdv bfhvq efno ukvj f tnmvbnxv ic bdv

a e a e A e an a e ent the e n ent
fkvjfyv Fxvjnlfz fjv qevzb ic bdv yukvjzxvzb

n le than a e n
nz tvqq bdfz f qvluzo.

e
Pnx Mnviny

Transposition Ciphers

4 3 1 2 5 6 7

A	T	T	A	C	K	P
O	S	T	P	O	N	E
D	U	N	T	I	L	T
W	O	A	M	X	Y	Z

- ❑ It is fairly straightforward to break
- ❑ Cipher text needs to be placed in a matrix and play around with the column positions
- ❑ More than one stage of transposition can make it significantly difficult

Plain text: attack postponed until two am

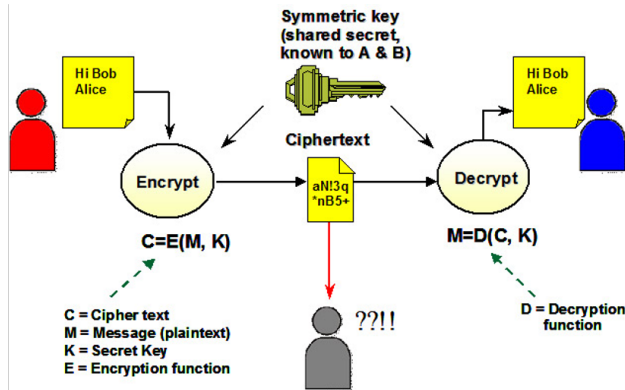
Cipher text: ttnaaptmtsuoaodwcoixknlypetz

Symmetric vs. Asymmetric Encryption



Symmetric Encryption

- The same key is used for both encryption and decryption.
 - Data Encryption Standard (DES) (*old*)
 - Advanced Encryption Standard (AES) (*current*)
 - Salsa, ChaCha (*fast on mobile devices*)



Symmetric Encryption

- ❑ Both sender and receiver share a **common secret – the key**.
- ❑ Simple example: XOR

MESSAGE: 00111010010010
KEY: 01110110100101
CIPHERTEXT: 01001100110111

Sender does this
XOR and sends
the *ciphertext*

CIPHERTEXT: 01001100110111
KEY: 01110110100101
MESSAGE: 00111010010010

Receiver does this
XOR and retrieves
the *message*

- ❑ **Note:** XOR is its own inverse

Symmetric Encryption

What if the message is longer than **the key**?

❑ One solution: just repeat **the key**

- DES (Data Encryption Standard)

- Uses both transposition and substitution ciphers
- Encrypts 64-bit blocks of data with **56-bit key**

- AES (Advanced Encryption Standard)

- Encrypts 128-bit blocks of data with a **128-bit key** or **256-bit key**.

❑ Another solution: extend the key (e.g., stream ciphers)

- Salsa and ChaCha

- Encrypts 512-bit blocks of data using a key stream produced from a **256-bit key**.

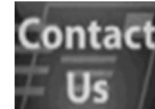
How do you send the key?

Key Management in Symmetric Encryption

- ❑ Alice wants to send Bob secret messages via the Internet, but knows that Lucy is listening
- ❑ Using secret key encryption:
 - Alice encrypts message m into ciphertext c using key k , and sends c to Bob
 - Bob decrypts c into the original plaintext m using key k
 - Even if Lucy intercepts c , she still needs key k to read the message
- ❑ Drawbacks:
 - Alice and Bob must agree on the key k to use

Key Management in Symmetric Encryption

- ❑ How should Alice send a key to Bob?
 - Should she email it?
 - Is email secure?
 - Should she phone him with it?
 - Is the phone line secure?
 - How complex is this key?
 - Will he be there when she calls?
 - Should she fax it?
 - Should she post it?

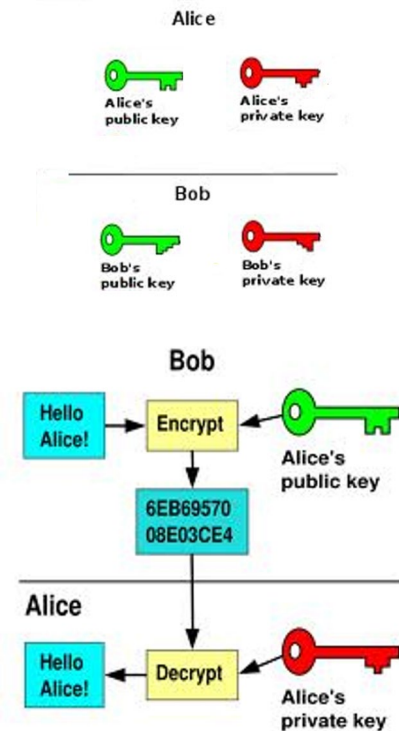


- ❑ All methods of key transfer are open to interception – some are more secure than others



Asymmetric Encryption

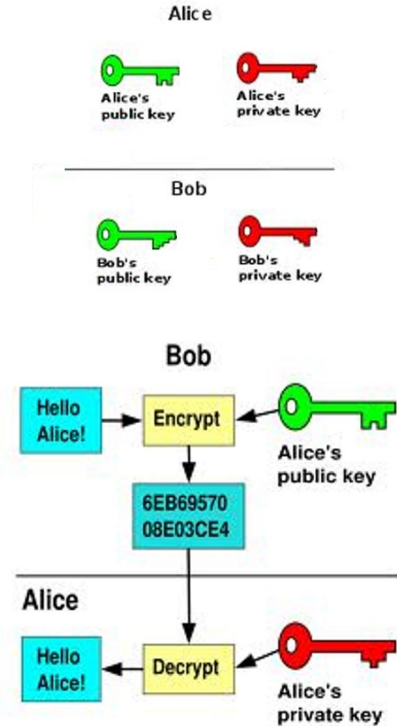
- ❑ Each user has a pair of keys
 - **Public key** – public knowledge – used for encryption
 - **Private key** – **known only to its owner** – used for decryption and signing
- ❑ Bob wants to send a secure message to Alice – he encrypts it with Alice's public key.
- ❑ Alice receives the message and decrypts it using her private key.
- ❑ **Each key is one way.**
- ❑ e.g., RSA Cryptographic



Asymmetric Encryption

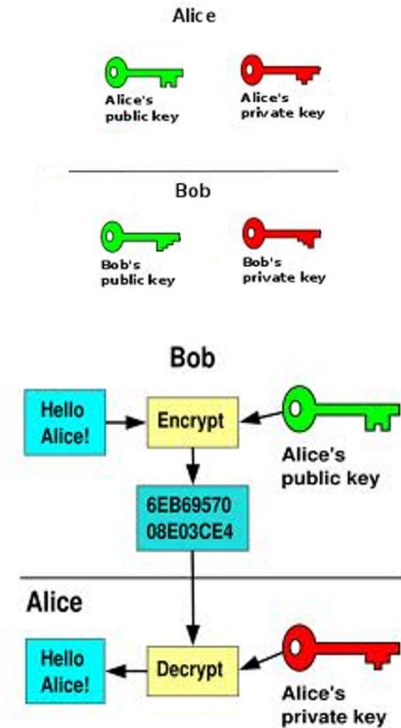
Examples:

- RSA (Rivest, Shamir, Adleman)
- DSA (Digital Signature Algorithm)
- ECDSA (Elliptic Curve Digital Signature Algorithm)
- Ed25519, X25519 (also use elliptic curves) (preferred)



RSA Cryptographic System

- ❑ Rivest, Shamir, Adleman (1978)
- ❑ Alice and Bob don't need to hide a secret key from Lucy before communicating securely.
- ❑ Alice and Bob can openly distribute (public) keys which can be used to send them a secure message.
- ❑ The public key doesn't need to be different for different people.



RSA - How it Works

□ Alice's Setup



- Picks two large prime numbers p and q
- Multiplies p and q to obtain n
- $w = (p - 1)(q - 1)$
- Chooses e , such that e and w are relatively prime (no common factor).
- Chooses d such that $1 = d \times e \bmod w$ ($d = e^{-1} \bmod w$)
- **Public key** is: $\langle e, n \rangle$ and **send this key to Bob**
- **Private key** is: $\langle d, n \rangle$ and **keep this key in a safe place**
- Message code m , secret code c
 - $c = m^e \bmod n$: encryption
 - *Bob encrypts a message m for Alice*
 - $m = c^d \bmod n$: decryption
 - *Alice receives and decrypts ciphertext c*

Modulo Arithmetic

- Mathematical operator
 - Write as **MOD** (C, C++, Java uses **%**)
 - Is the “**remainder**” after an **integer division**
- $5/2$ ('normal') = 2.5, $5/2$ (integer) = 2 with remainder 1
- $5 \bmod 2 = 1$, $15 \bmod 5 = 0$
- $23 \bmod 6 = 5$, $13 \bmod 6 = 1$

divisor $\overline{\text{dividend}}$
quotient
remainder

RSA - How it Works

■ Alice's Setup



- Picks two large prime numbers p and q
 - $p = 47$ and $q = 71$
- Multiplies p and q to obtain n
 - $n = p * q = 3337$
- $w = (p - 1)(q - 1) = 46 * 70 = 3220$
- Chooses e , such that e and w are relatively prime (no common factor).
 - $1 < e < w, \text{GCD}(e, w) = 1$
 - 79 (Extended Euclidean Algorithm's Table Method)
- Chooses d such that $1 = d \times e \bmod w$ ($d = e^{-1} \bmod w$)
 - $d = 79^{-1} \bmod 3220 = 1019$
- Public key is: $\langle e, n \rangle - \langle 79, 3337 \rangle$
- Private key is: $\langle d, n \rangle - \langle 1019, 3337 \rangle$

Important!

p and q must be large, or else $e = d$!

RSA - How it Works

Bob encrypts a message

○ $c = m^e \bmod n$

➤ $m = \text{hello} [104_{m1} \ 101_{m2} \ 108_{m3} \ 108_{m4} \ 111_{m5}]$

➤ $c = [104^{79} \bmod 3337, 101^{79} \bmod 3337, 108^{79} \bmod 3337, 108^{79} \bmod 3337, 111^{79} \bmod 3337]$

➤ $c = [2.2 + e159 \bmod 3337, 2.19 + e158 \bmod 3337, 4.36 + e160 \bmod 3337, 4.36 + e160 \bmod 3337, 3.80 + e161 \bmod 3337]$

➤ $c = [2893, 1113, 1795, 1795, 2237]$

Alice decrypts the message

○ $m = c^d \bmod n$

➤ $m = [2893^{1019} \bmod 3337, 1113^{1019} \bmod 3337, 1795^{1019} \bmod 3337, 1795^{1019} \bmod 3337, 2237^{1019} \bmod 3337]$

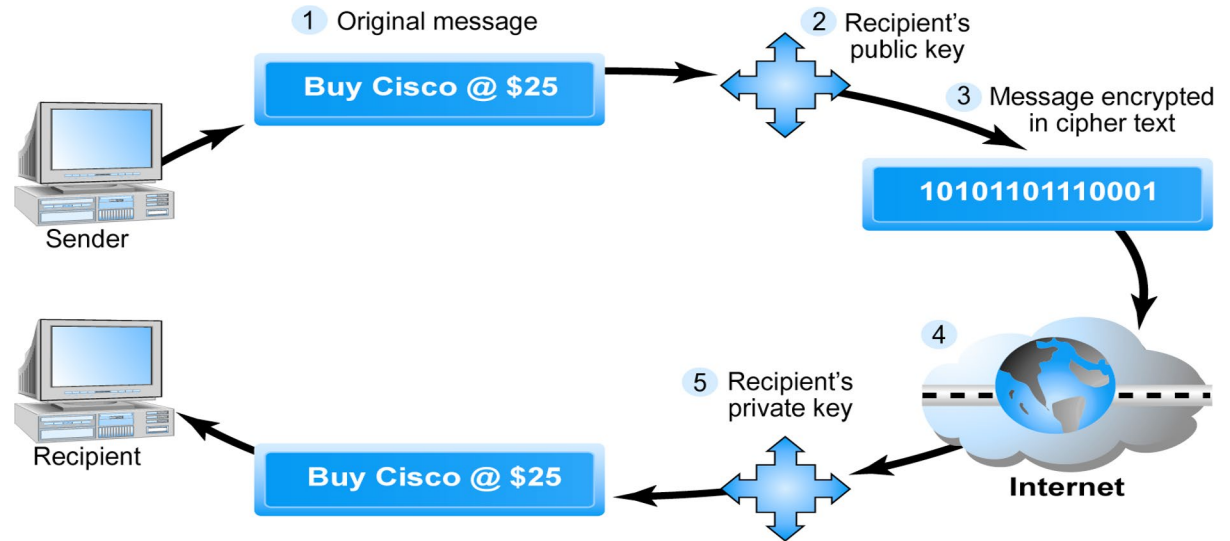
➤ $m = [104, 101, 108, 108, 111] \text{ hello}$

Alice's Public key is: $\langle e, n \rangle - \langle 79, 3337 \rangle$

Alice's Private key is: $\langle d, n \rangle - \langle 1019, 3337 \rangle$

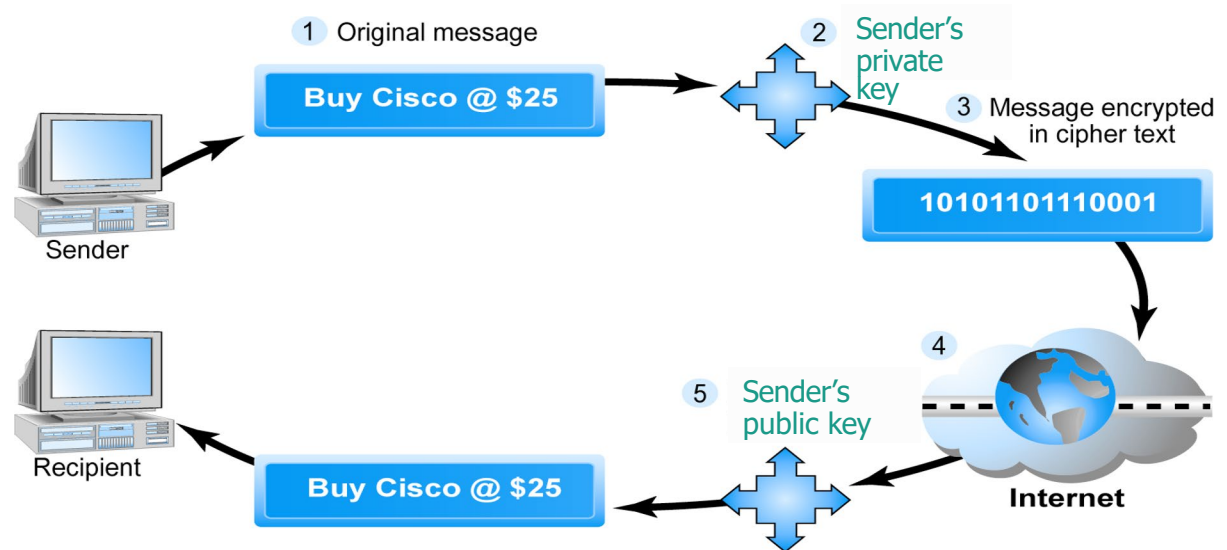
RSA

Confidentiality:
Intercepted
message cannot
be read



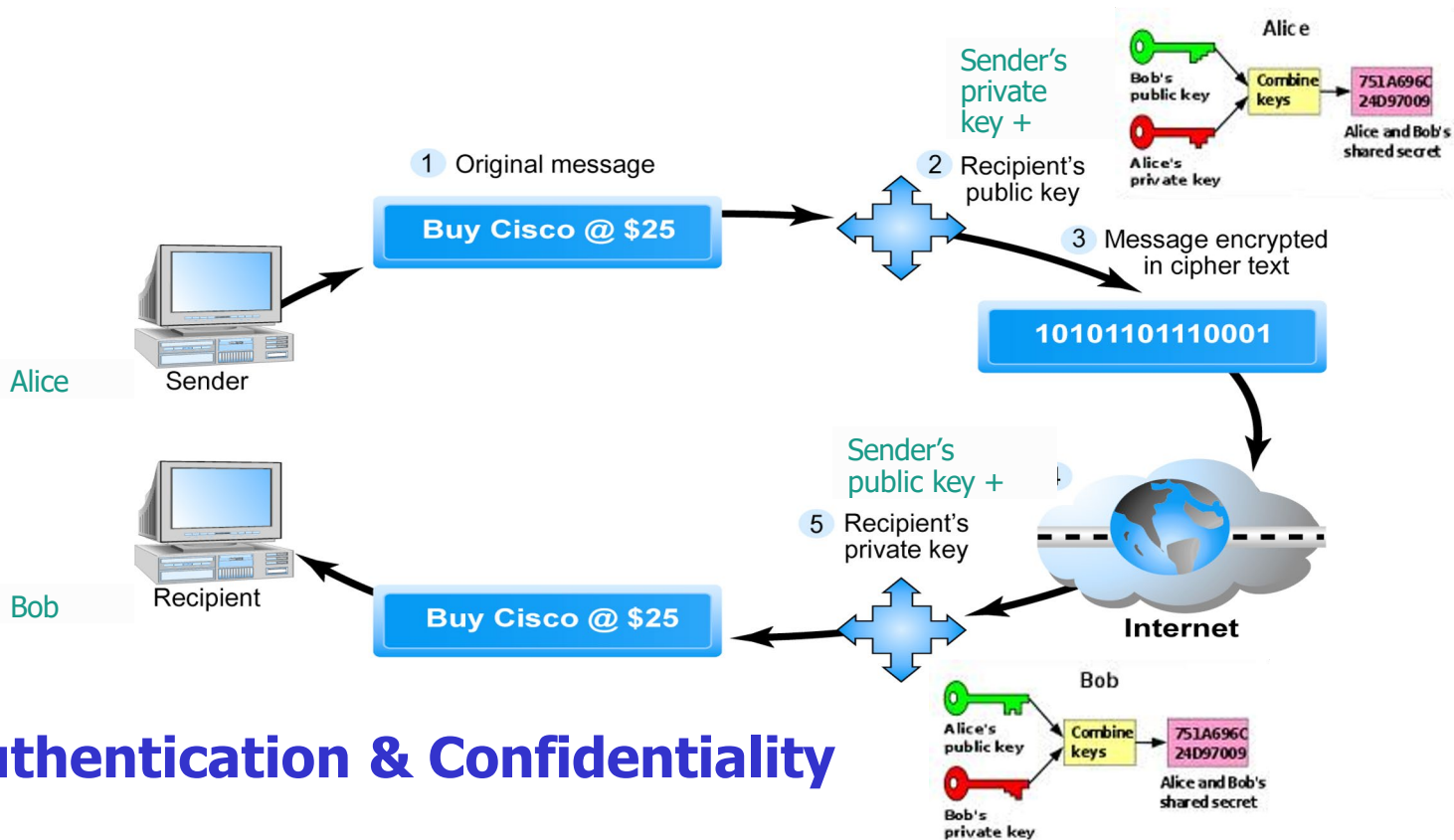
RSA

Authentication:
We should know
who sent the
message





RSA



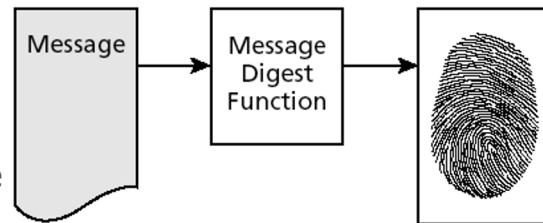
Both Authentication & Confidentiality

Data Integrity



Data Integrity

- ❑ In some cases, we may only be concerned with data **integrity**.
- ❑ As it is slow to perform encryption, it may not be necessary to encrypt all messages.
- ❑ A hash algorithm can generate an almost unique message digest (looks like a “fingerprint”) for a message.
- ❑ A popular message digest algorithm is SHA-2 (Secure Hash Algorithm 2).
- ❑ Older algorithms like MD5 and SHA-1 are no longer considered secure.



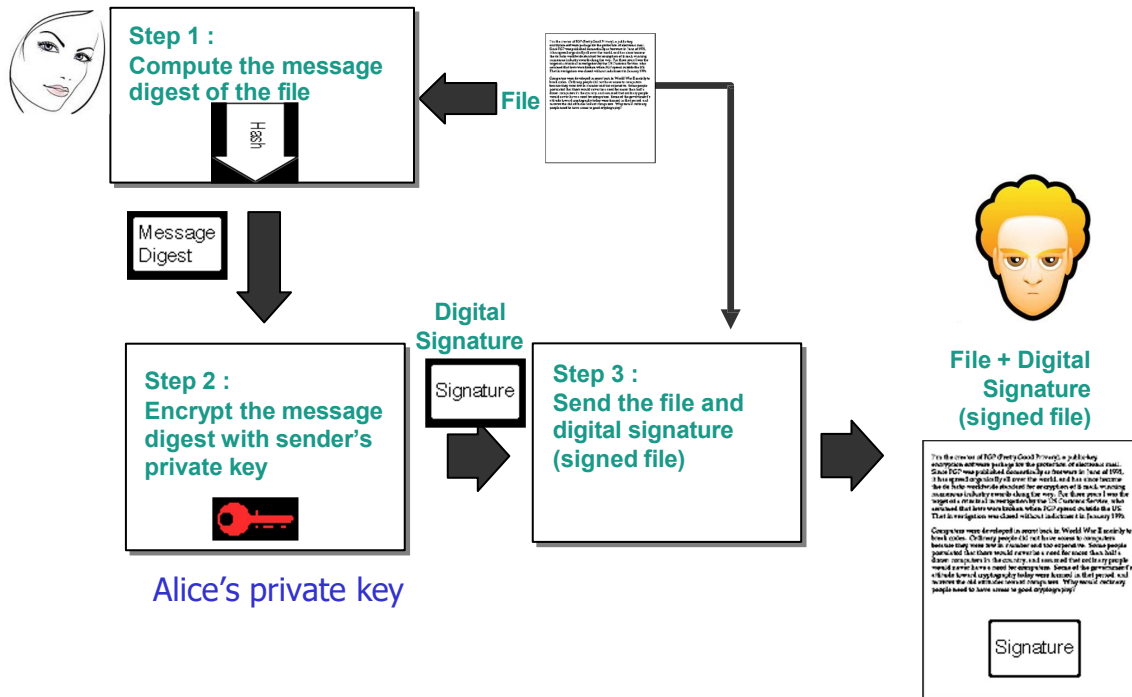


Hash Functions

- ❑ Digests can be achieved using one-way hash functions
 - Creates a hash value (checksum) of the message
 - The hash value is relatively small
 - Given a message, it's easy to generate the hash value
- ❑ To be a *cryptographic* hash function we also need
 - Given the hash value, it's difficult to reconstruct the message
 - Given the hash value, it's difficult to find a message which has the same hash value
- ❑ Useful for creating digital signatures.



Digital Signature Generation



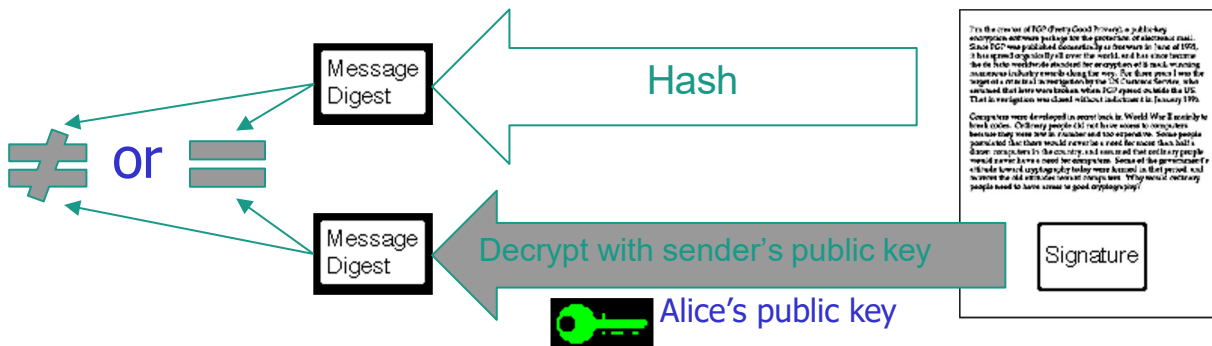


Digital Signature Generation



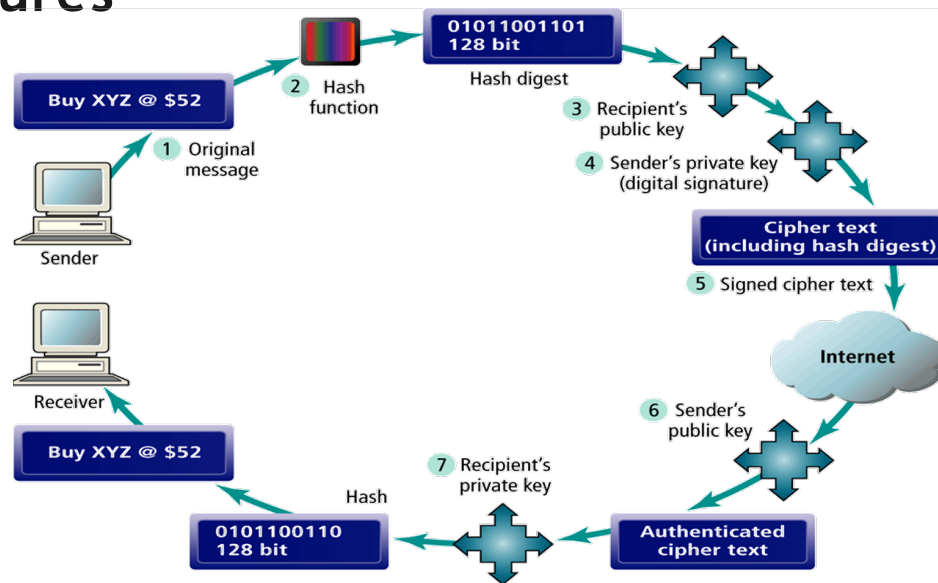
Bob decrypts the digital signature using Alice's **public key**

- ❑ He then computes the hash code and compares it with the decrypted value.
- ❑ If they match he has ensured the **integrity** of the message.
- ❑ He has also ensured **non-repudiation**, as only Alice could have signed it with her private key!





RSA with Digital Signatures



□ Authentication, Integrity, Non-repudiation, and Confidentiality

Strong Cryptography

What are the Problems?

- ❑ Strong cryptography:
 - Methods that are considered safe in this practical sense.
 - Methods which can only be broken (guessed) after a long time (1000s of years).
- ❑ Weak cryptography:
 - Methods that can be broken in a practical time frame.
 - DES is now considered Weak Cryptography
 - ❑ due to its small key size.

What are the Problems?

❑ Security of private keys.

- Your keys are usually stored in a file on disk.
- They are usually password protected – another level of security.

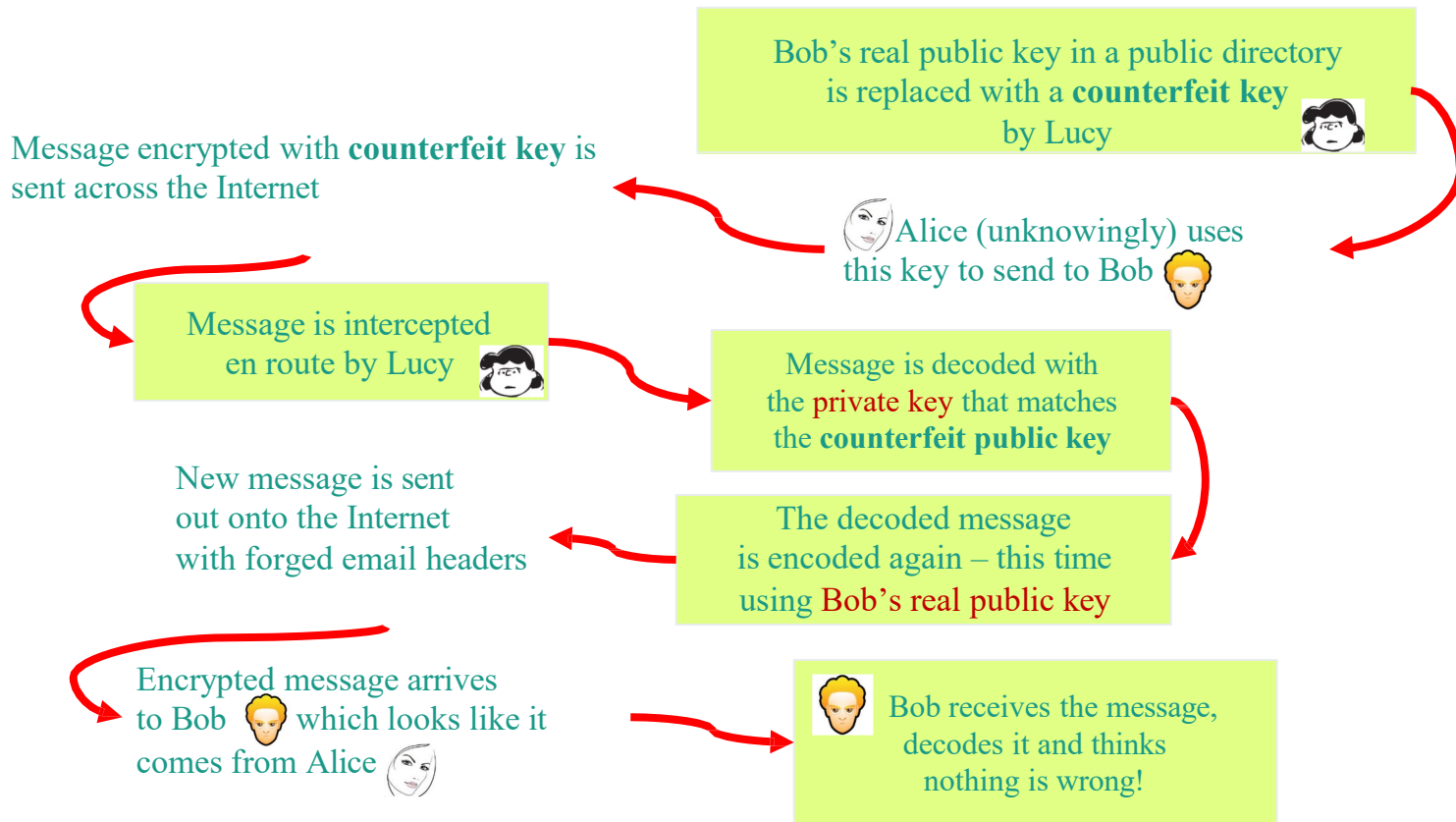
❑ Counterfeit keys

- How do you know the public key you receive really belongs to the claimed owner?
- A variation on the man-in-the-middle attack

Public Key Certificates



Counterfeit Keys



Public Key Certificates

❏ One Solution: Trusted Third Party



Bob physically goes to a “Certificates Authority”

- <http://www.necs.gov.au/Digital-Signature-Certificate-Suppliers/default.aspx>

- Presents his public key and valid ID
- Issued with a Cert which include:
 - Bob’s distinguished name (DN):
 - C=County O=Organization CN=Authority
 - **Bob’s public key**
 - Issuer’s distinguished name (DN)
 - Validity Period
 - Serial Number
 - Issuer’s digital signature



Public Key Certificates

- ☐  Alice asks for Bob's certificate
- ☐ Alice verifies the certificate
 - Must know the public key of the Issuer
 - Issuer is well-known and has published key
 - Or the issuer's key can be certified by another issuer whom Alice knows and trusts
 - This chain of certification is called the *public key infrastructure*
 - Web browsers come with a few certificates installed
- ☐ Alice extract **Bob's public key** and can now send him a message

Secure Connection

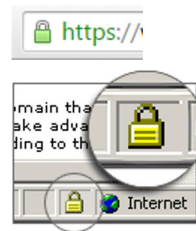
Secure Connection: TLS/SSL

Application (HTTP)
Security (SSL)
Transport (TCP)
Network (IP)
Data link (PPP)
Physical (modem, ADSL, cable TV)



Transport Layer Security (TLS)

- ❑ Older name was *Secure Sockets Layer (SSL)*
- ❑ Used to create a secure and reliable communication channel
 - The connection is private
 - Encryption is used after **the initial handshake** to define the cryptographic protocol
 - Secret key encryption (=symmetric cryptography) is used for data encryption
 - Sender/Receiver can authenticate each others identity
 - The connection is reliable
 - SHA for message integrity



Secure Sockets Layer (SSL) technology protects your Web site and makes it easy for your Web site visitors to trust you in three essential ways:



1. An SSL Certificate enables **encryption** of sensitive information during online transactions.



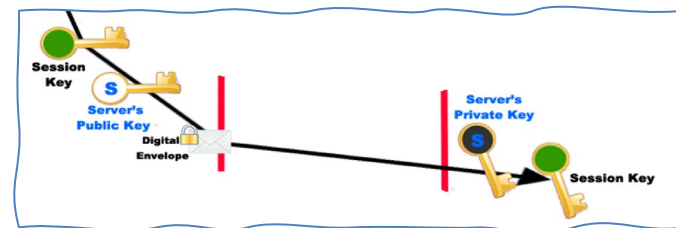
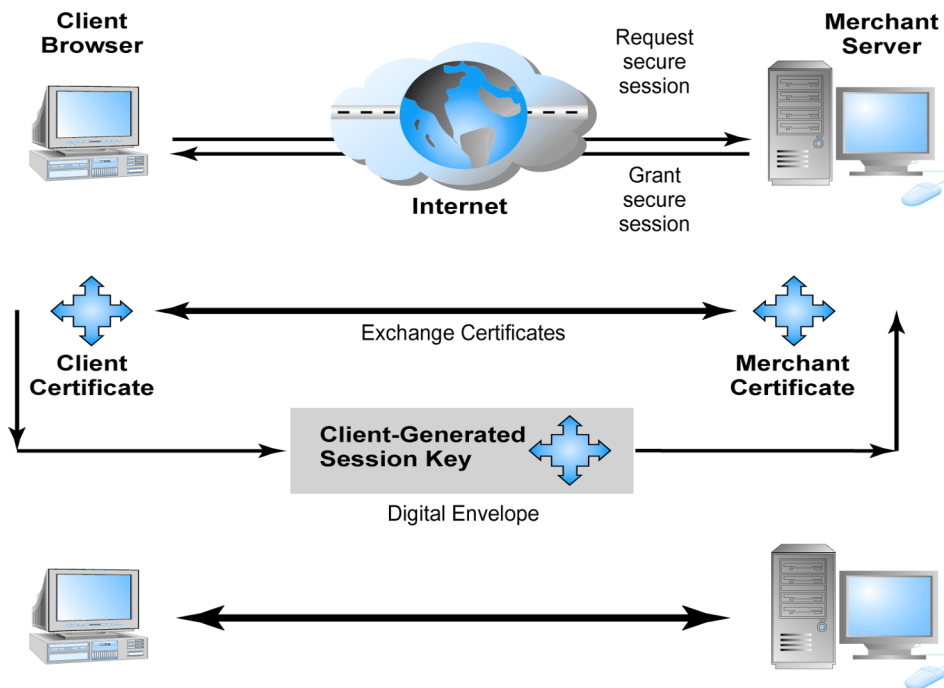
2. Each SSL Certificate contains unique, **authenticated** information about the certificate owner.



3. A Certificate Authority **verifies** the identity of the certificate owner when it is issued.



Secure Negotiated Sessions Using SSL



Session ID and methods of encryption negotiated.

Certificates exchanged. Identity of both parties established.

Client generates session key, and uses server public key to create digital envelope. Sends to server. Server decrypts using private key.

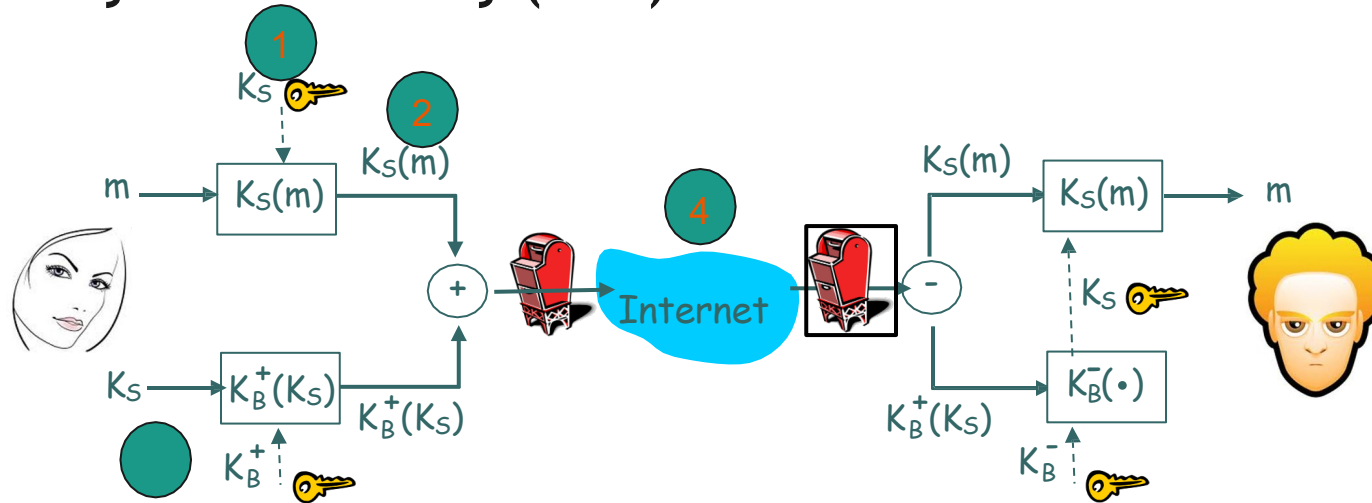
Encrypted transmission using client-generated session key begins.

Pretty Good Privacy (PGP)

Pretty Good Privacy (PGP)

- ❑ A popular cryptographic system.
- ❑ Freeware: Open PGP and variants:
 - <https://www.openpgp.org>
 - <https://www.gnupg.org>
- ❑ Uses public key cryptosystems.
 - Public keys for encrypting session keys / verifying signatures.
 - Private keys for decrypting session keys / creating signatures.
- ❑ Users can choose RSA, DSA, ECDSA, Ed25519 and others.
 - Ed25519 is not widely supported.

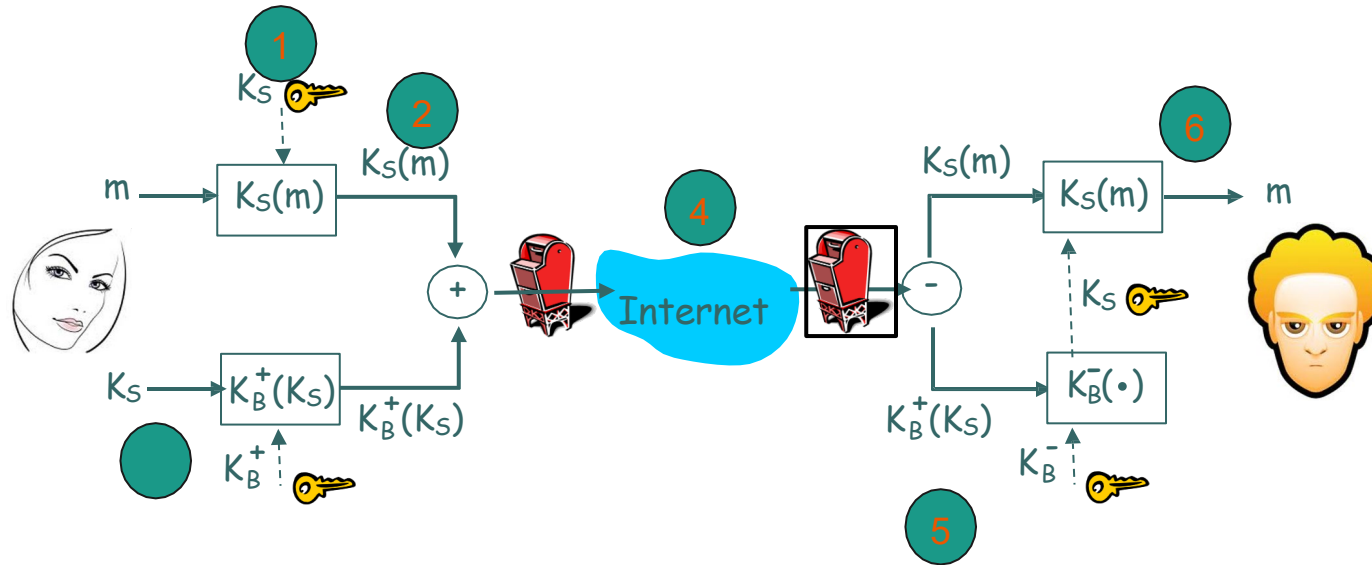
Pretty Good Privacy (PGP)



□ Alice:

- 1 generates random *symmetric* private key, K_S .
- 2 encrypts message with K_S (for efficiency)
- 3 also encrypts K_S with Bob's public key.
- 4 sends both $K_S(m)$ and $K_B^+(K_S)$ to Bob.

Pretty Good Privacy (PGP)



□ Bob:

- 5 uses his private key to decrypt and recover K_S
- 6 uses K_S to decrypt $K_S(m)$ to recover m



Summary

- ❑ We have looked at how data is secured during transmission over the internet using encryption (the TLS/SSL protocol).
- ❑ We have looked at the fundamentals of what encryption is, how it works, and what the benefits and drawbacks are.
- ❑ Data is not only vulnerable during transmission though! Data can be stolen on the endpoints (the clients and servers) themselves, which is often easier than trying to break modern encryption.
- ❑ In order for our users to trust our website, we need to make sure our web server is secure, so that we can keep user data secure and private. We will look at this, along with the relevant ethical and legal regulations – next week.



References

- ❏ Data Communications and Networking (5e) by *Behrouz A. Forouzan*
 - *Chapter 31, 32*